

# Patient Health Record Consent Management System

Software Engineering Lab 1 — Requirements Engineering & UML Use-Case Modelling

## Patient Health Record Consent Management System

Software Engineering Lab 1 — Requirements Engineering & UML Use-Case Modelling

Requirements Table

| Req ID  | Type                                   | Description                                                                                                                                                   | Priority | Acceptance Criteria                                                                                                                                                              | Rationale                                                                                                         |
|---------|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| FR-001  | Functional                             | The system shall allow patients to grant time-bounded (e.g., 24-hour) access permissions for specific diagnostic records to verified clinic doctors.          | High     | <b>Pass:</b> Clinic access automatically revokes upon expiry timestamp.<br><b>Fail:</b> Clinic accesses records after consent expiration.                                        | Core function enabling patient-controlled, time-limited data sharing.                                             |
| FR-002  | Functional                             | The system shall allow a patient to revoke a previously granted access permission at any time before its scheduled expiry.                                    | High     | <b>Pass:</b> A clinic access attempt is denied within 5 seconds of the patient tapping "Revoke". <b>Fail:</b> Clinic can still view the record after revocation.                 | Patients must retain immediate, continuous control over who can view their health data.                           |
| FR-003  | Functional                             | The system shall require a clinic doctor to submit an access request specifying patient ID, record type, and reason for access before consent can be granted. | Medium   | <b>Pass:</b> A request submitted without a reason field is rejected with an error message. <b>Fail:</b> A request lacking a reason is accepted and forwarded to the patient.     | Capturing purpose-of-access supports informed patient decisions and audit accountability.                         |
| FR-004  | Functional                             | The system shall send the patient a notification (in-app, SMS, or email) at least one hour before an active consent grant expires.                            | Medium   | <b>Pass:</b> Notification logs show a reminder sent 55–65 minutes before every grant's expiry timestamp.<br><b>Fail:</b> No reminder is logged, or it falls outside that window. | Gives patients a timely opportunity to extend or let access lapse before it expires.                              |
| FR-005  | Functional                             | The system shall allow a patient to view a complete, filterable audit trail of all consent grants, revocations, and record accesses linked to their account.  | High     | <b>Pass:</b> Filtering by a date range returns all matching events within 3 seconds.<br><b>Fail:</b> Events are missing or the query fails.                                      | Transparency into access history builds patient trust and supports regulatory compliance.                         |
| NFR-001 | Nonfunctional (Performance & Security) | All consent grant, revoke, and access events shall be permanently written to an append-only audit trail.                                                      | High     | <b>Pass:</b> Benchmarking tests confirm target latency and security standards under simulated peak load.                                                                         | Guarantees a tamper-evident record of every consent-related action for compliance and dispute resolution.         |
| NFR-002 | Nonfunctional (Security)               | All patient health records and consent data shall be encrypted using AES-256 at rest and TLS 1.2 or higher in transit.                                        | High     | <b>Pass:</b> Security scan confirms no record is stored or transmitted unencrypted.<br><b>Fail:</b> Any record is found in plaintext.                                            | Protects sensitive health data from unauthorized disclosure and supports healthcare data-protection requirements. |